# HANFIS: A Hierarchical Adaptive Neuro-Fuzzy Inference System for Evidence-Based Dynamic Cybersecurity Risk Scoring in Cloud-Native Kubernetes Deployments

Mohammad Hafiz Hersyah[1*], Derisma Derisma[2] and Budi Rahmadya[1]

[1*]Computer Engineering Department, Andalas University, Kampus Limau Manis Street, Padang, 25162, West Sumatera, Indonesia.
[2]Informatics Department, Andalas University, Kampus Limau Manis Street, Padang, 25162, West Sumatera, Indonesia.

*Corresponding author(s). E-mail(s): mohammadhafizhersyah02@it.unand.ac.id;
Contributing authors: derisma@it.unand.ac.id; budi-r@it.unand.ac.id;

**Abstract**

Static, expert-weighted fuzzy risk scores go stale between elicitations, and a flat Adaptive Neuro-Fuzzy Inference System (ANFIS) over seven risk inputs needs 128 rules and 1,052 parameters. We built a hierarchical ANFIS (HANFIS) that separates vulnerability and environmental reasoning before an integration tier adds threat intelligence (34 rules, 176 parameters) and tested it against simple baselines. The target is exploitability exposure from sealed weekly Exploit Prediction Scoring System (EPSS) and Known Exploited Vulnerabilities (KEV) snapshots for 120 container images (6,357 labelled asset-weeks), evaluated with grouped, embargoed splits. A 4-week persistence baseline lowers mean squared error relative to climatology by 97%; a single Common Vulnerability Scoring System (CVSS) score, by 22%. Under a protocol frozen before training, HANFIS reduces error by 96.7% against CVSS, 69.6% against a ridge model on all

seven inputs and 66.5% against a parameter-matched flat ANFIS (95% bootstrap intervals excluding zero; the last margin comes largely from one fold), and it is not distinguishable from persistence. Post hoc analyses narrow these gains. Exact Shapley attribution puts 78.9% on exploitability and the KEV indicator, both label ingredients; without them HANFIS has no skill over CVSS (skill $\mathbf{-0.135}$, interval $\mathbf{-0.336}$ to $\mathbf{0.046}$). A four-parameter formula of those two inputs, $\mathbf{100\,\max(x_2, 0.1\,x_7)}$, beats HANFIS at four weeks (skill $\mathbf{-0.534}$, interval $\mathbf{-1.438}$ to $\mathbf{-0.208}$). In a pre-registered forward evaluation the formula beat persistence and HANFIS did not. On this target HANFIS offers a printable rule base and no gain in accuracy, and the data cannot show whether environmental context helps.

**Keywords:** Adaptive Neuro-Fuzzy Inference System, Hierarchical fuzzy systems, Exploit prediction, Container security, Kubernetes, Pre-registered evaluation, Negative result

# 1 Introduction

Cloud-native computing has changed the scale and the temporal behaviour of enterprise attack surfaces. Applications run as loosely coupled microservices on container orchestration, and Kubernetes Pods are ephemeral by design: they are created, replaced, rescheduled or terminated as conditions change Chandramouli (2019); The Kubernetes Authors (2026). A risk value calculated before a deployment, a configuration change or a new exploitation signal may therefore no longer describe the workload when a decision is needed. Zero Trust Architecture (ZTA) adds to the problem by requiring access decisions to consider the current identity, resource and operational context Rose et al. (2020); Chandramouli and Butcher (2023).

Our previous Fuzzyfortify framework Hafiz Hersyah et al. (2025) scored cybersecurity risk with fuzzy multi-criteria reasoning over expert knowledge, which remains useful when observations are incomplete and priorities cannot be expressed as crisp thresholds. Its main limitation is temporal: expert-derived weights and rules stay fixed until they are elicited again, so a score can stay unchanged while new evidence shows active exploitation, weaker multifactor authentication, wider Kubernetes exposure or

delayed remediation. What is missing is a reproducible mechanism that keeps the rule structure readable, learns the input–output relationship from observed data, and recalculates the score as the evidence changes.

An Adaptive Neuro-Fuzzy Inference System (ANFIS) combines readable fuzzy rules with data-driven adjustment of membership and consequent parameters Jang (1993). A flat ANFIS becomes hard to train and inspect as its input dimension grows: under exhaustive grid partitioning, $n$ inputs with $m$ membership functions each may require $m^n$ rules, and for the seven inputs considered here two membership functions per input already give $2^7 = 128$ rules, with matching growth in adaptive parameters and in the least-squares problem.

This study builds and tests a domain-informed Hierarchical Adaptive Neuro-Fuzzy Inference System (HANFIS). In the first tier, a vulnerability subsystem combines the CVSS Base Score, Exploitability and Patch Risk into a Vulnerability Risk Index, and an environmental subsystem combines Multi-Factor Authentication (MFA) Risk, Kubernetes Exposure and Asset Criticality into an Environmental Risk Index. A second-tier integration subsystem combines the two indices with a time-varying Threat Intelligence input into the Dynamic Risk Score. The organisation follows established risk-assessment logic, in which vulnerability and threat information are read within an organisational context Joint Task Force Transformation Initiative (2012), and it keeps the CVSS Base Score apart from the dynamic threat signal, as CVSS v4.0 separates its Base, Threat and Environmental metric groups FIRST.org, Inc. (2023). In this study the threat input is the CISA KEV indicator, and the Exploit Prediction Scoring System (EPSS), which estimates the probability that a published vulnerability will be exploited in the following 30 days Jacobs et al. (2021), enters through exploitability.

The hierarchical decomposition also changes the rule count directly. If every input uses $m$ membership functions, the exhaustive rule count is reduced from

$$R_{\text{flat}} = m^7 \tag{1}$$

to

$$R_{\text{HANFIS}} = 2m^3 + m_I^2\, m, \tag{2}$$

where $m$ is the number of membership functions on each of the seven raw inputs and $m_I$ is the number of membership functions on the two intermediate variables $v$ and $e$ inside the integration tier (Section 3.2). With the frozen configuration $m = 2$, $m_I = 3$, the proposed structure requires 34 candidate rules rather than 128, a 73.4% reduction; the corresponding parameter count falls from 1,052 to 176, an 83.3% reduction (Table 1). Hierarchical fuzzy systems limit dimensionality-driven rule growth while retaining nonlinear approximation capability Wang (1998); Ojha et al. (2019), but a lower rule count does not by itself give better estimates, because hierarchical compression may discard cross-subsystem interactions. The architecture is therefore compared with a full grid-partitioned flat ANFIS, a parameter-matched clustering-based flat ANFIS and simple baselines on identical observations and partitions. Fuzzyfortify is not compared, because the asset-week data do not produce its native inputs (Section 4.3).

Edge deployment and a policy-translation layer that maps risk states to bounded responses are outside the claims of this paper. The computational cost of HANFIS is compared with flat ANFIS variants on one machine (Section 4.15), and both extensions are left to future work (Section 6).

The aim of this study is to find out whether a domain-informed hierarchical decomposition earns its place in cloud-native vulnerability risk scoring. We build a HANFIS with a reduced rule base and intermediate variables meant to be interpretable, test how

faithful its rule-level explanations are (Section 4.6), and compare its estimation error with flat ANFIS variants and with two baselines that need no neuro-fuzzy training: a 4-week persistence forecast and a formula of two inputs. On the realised exploitability-exposure target the answer is mostly negative. The label is dominated by its own recent history, HANFIS is not distinguishable from persistence, and a four-parameter formula beats it in a pre-registered forward window. The paper reports that result with the frozen protocol, the post hoc analyses that explain it, and the limits of what the data can show.

The contributions of this study are:

**C1.** A domain-informed HANFIS architecture, proposed as a design, that separates vulnerability and environmental reasoning before integrating their outputs with threat intelligence to produce a Dynamic Risk Score recalculated weekly from sealed EPSS and KEV snapshots. Unlike the speaker-verification HANFIS of Soozanchi-K. et al. (2010), its three tiers follow a vulnerability, environment and threat decomposition, and the evaluation does not show that the environmental panel contributes (Sections 4.7 and 4.8).

**C2.** A hierarchical decomposition that changes exhaustive rule growth from $m^7$ to $2m^3 + m_I^2 m$ (the arithmetic of hierarchical fuzzy systems Raju et al. (1991); Wang (1998)), accompanied by an unregistered measurement of parameter count, training time, peak memory, throughput and single-row inference latency against flat ANFIS variants (Section 4.15). It lowers parameters and peak training memory and raises batch throughput relative to the full flat model, but not training time or single-row latency.

**C3.** An operational definition of seven risk inputs (CVSS Base severity, exploitability, patch condition, MFA weakness, Kubernetes exposure, asset criticality, and time-varying threat evidence, without duplicating CVSS threat metrics) and of a realised 30-day exploitability-exposure target built from sealed EPSS and KEV snapshots.

The target has no impact term, so it measures exploitability exposure, not full cybersecurity risk.

**C4.** A reproducible evaluation against persistence, single-CVSS, ridge and flat ANFIS baselines (full and parameter-matched), using predictive and computational metrics under common grouped, embargoed temporal partitions. Post hoc information-minimal and formula baselines, an ablation of the label-ingredient inputs and a horizon sweep complement it (Sections 4.8 and 4.11). A pre-registered forward evaluation on six weeks after the protocol freeze tests the formula and HANFIS against persistence (Section 4.16). A Fuzzyfortify comparison is not claimed (Section 4.3).

**C5.** A pre-registered negative result for the hierarchical model on this target. Persistence alone removes 97% of the error relative to climatology, so a model trained on a label of this kind has to be judged against it. In the forward window HANFIS was not better than persistence and was worse than a four-parameter formula (Section 4.16), and its skill rests on two inputs that are also ingredients of the label (Sections 4.7 and 4.8). The result concerns one architecture, one target and one six-week window, and it is not a verdict on neuro-fuzzy models in general.

The empirical analysis is guided by the following hypotheses:

***H1a: Improvement over static expert scoring.*** HANFIS will produce significantly lower risk-estimation error than a single CVSS score, the current-practice baseline.

***H1b: Improvement over naive persistence.*** HANFIS will reduce mean squared error relative to a causal 4-week persistence forecast by at least a smallest-effect-size-of-interest of 5%, with the lower bound of its 95% confidence interval above zero. Persistence, not a single CVSS score, is the empirically strongest baseline observed on the pilot dataset (Section 4.3) and is therefore the bar HANFIS must clear, not an optional comparator.

***H1c: Value of hierarchical structure over a linear model.*** HANFIS will be non-inferior to a ridge-regularised linear model on the same seven inputs, with superiority reported when the confidence interval excludes zero.

***H2: Computational efficiency.*** For an equivalent input set and membership-function configuration, HANFIS will require significantly fewer fuzzy rules and adaptive parameters and will reduce training time, peak memory, and inference latency relative to flat grid-partitioned ANFIS.

***H3: Performance preservation.*** The predictive performance of HANFIS will be non-inferior to a parameter-matched flat ANFIS (FlatANFISMatched, ±5% parameters) within a prespecified margin, despite the reduced rule-base complexity.

***H4: Threat responsiveness.*** Including time-varying Threat Intelligence will improve the prioritization of actively exploited or high-probability vulnerabilities compared with an otherwise identical HANFIS without this input.

**H5 (edge execution)**, originally a fifth hypothesis, was dropped: the edge node of the testbed is a telemetry client only and HANFIS runs cluster-side, so no edge timing evidence exists. H1a–H1c and H2–H3 are pre-registered against the frozen protocol, seed list, and data split described in Section 4.2; results are reported in Section 4.3 (Table 3). In the frozen protocol, H2 and H3 are tested together by one comparison, the skill score against FlatANFISMatched with a non-inferiority margin of $-0.05$ on the lower confidence bound; it is labelled H2/H3 below. The computational part of H2 (training time, memory, latency) was not part of that protocol and is reported separately as an unregistered measurement (Section 4.15).

**H4 (threat responsiveness)** was not tested as stated: the registered protocols contain no test of it, and the closest procedure, an ablation of $x_7$ alone run afterwards, is reported as a post hoc, unregistered analysis (Section 4.9).

Section 2 reviews related work; Section 3 describes the architecture, the testbed, the target and the forward-evaluation design; Section 4 reports the results; Section 5 discusses them and their limits; and Section 6 concludes.

# 2 Literature Review

## 2.1 ANFIS

ANFIS integrates the learning ability of neural networks into the design of a fuzzy inference system Jang (1993): input–output data pairs tune the parameters of IF–THEN rules whose antecedent and consequent parts follow a Sugeno-type model. With two inputs $x_1$ and $x_2$ and linear outputs $f$, two such rules read Jang (1993):

Rule # 1. IF $x_1$ is $A_1$ AND $x_2$ is $B_1$ THEN

$$f_1 = p_1 \cdot x_1 + q_1 \cdot x_2 + r_1$$

Rule # 2. IF $x_1$ is $A_2$ AND $x_2$ is $B_2$ THEN

$$f_2 = p_2 \cdot x_1 + q_2 \cdot x_2 + r_2$$

The original learning scheme alternates a least-squares solution of the consequent parameters with gradient steps on the premise parameters Jang (1993). Later work replaced one or both halves of that scheme: subtractive clustering places the initial rules at data-density peaks instead of on a grid Chiu (1994), and population-based or expectation-maximisation learners have been compared with gradient descent on classification benchmarks Jabeen et al. (2023). We use the hybrid scheme with a closed-form ridge step for the consequents and Adam for the premises (Section 3.2), and we use subtractive clustering only to initialise the parameter-matched flat comparator.

The term "hierarchical ANFIS" and the acronym HANFIS were used earlier for speaker verification with three groups of sound features Soozanchi-K. et al. (2010). The present work claims the domain decomposition into vulnerability, environmental and threat tiers, the temporal, evidence-sealed target of Section 3.4 and the real-world evaluation protocol, and makes no claim to the term.

## 2.2 Hierarchical fuzzy systems and rule-base reduction

A flat fuzzy system with $n$ inputs and $m$ membership functions per input needs up to $m^n$ rules. Raju, Zhou and Kisner showed that arranging the inputs in a hierarchy of low-dimensional subsystems makes the rule count grow linearly in $n$ Raju et al. (1991), and Wang proved that such hierarchies remain universal approximators Wang (1998). Zeng and Keane later gave conditions under which a hierarchical approximation needs fewer rules and parameters than a flat one for the same accuracy Zeng and Keane (2005). Brown and co-authors had already framed the same problem for neurofuzzy models in 1995 Brown et al. (1995). Torra's review catalogues how such hierarchies are built, including the choice of which inputs share a subsystem and how intermediate variables are defined Torra (2002). Lee, Chung and Yu argued that the intermediate variables should keep a readable meaning if the hierarchy is to stay interpretable Lee et al. (2003); our choice of three membership functions on the two intermediate indices follows that argument (Section 3.2), and Section 4.10 reports how far the trained models honour it. Ojha, Abraham and Snášel place hierarchical fuzzy systems among five design families for fuzzy inference and note that the families are often combined Ojha et al. (2019). A more recent survey organises Takagi–Sugeno–Kang fusion into hierarchical, wide and stacked arrangements and treats rule explosion as the main reason for all three Zhang et al. (2024).

Recent applications show the range of the idea and how it is usually evaluated: a Mamdani ANFIS with a hierarchical rule base, trained online by deep deterministic

policy gradient and assessed on a single simulated vehicle run Juston et al. (2024); three chained ANFIS modules for driving-behaviour classification and controller tuning, validated on one 70/30 split Parthiban and Krishna (2026); and a hierarchical fuzzy controller for robot formation compared in simulation with PID, sliding-mode, fuzzy and ANFIS controllers Wu and Zaman (2025). These studies report point estimates from one run or one split, and none compares the hierarchical model with a persistence or closed-form baseline on the same data. The present study keeps the hierarchy argument of Raju et al. (1991); Wang (1998) and evaluates it with grouped, embargoed splits, bootstrap intervals, a persistence baseline and a pre-registered forward test.

## 2.3 Exploit prediction and vulnerability prioritisation

The inputs that carry the skill in this study, exploitability and the KEV indicator, come from a separate literature on which vulnerabilities get exploited. Allodi and Massacci used case-control studies to show that a high CVSS score alone is a weak predictor of exploitation in the wild Allodi and Massacci (2014). Jacobs and co-authors then compared remediation strategies by how many exploited vulnerabilities each one covers for a given patching effort and argued for strategies built on exploit prediction Jacobs et al. (2020). That work led to EPSS, a model that estimates the probability that a vulnerability will be exploited in the next 30 days Jacobs et al. (2021), and to its third version, built with a community special interest group and reported to improve on its predecessors Jacobs et al. (2023). The Stakeholder-Specific Vulnerability Categorization proposed decision trees as an alternative to a single severity number Spring et al. (2021). Koscinski and co-authors compared CVSS, SSVC, EPSS and Microsoft's Exploitability Index on 600 vulnerabilities and found that the systems rank the same vulnerabilities differently, with consequences for teams that rely on one of them Koscinski et al. (2025). Shimizu and Hashimoto combine the three public signals in a fixed order, filtering first by KEV membership or an EPSS threshold

and then by CVSS Shimizu and Hashimoto (2026). CISA's Known Exploited Vulnerabilities catalogue is the public record behind the KEV indicator Cybersecurity and Infrastructure Security Agency (2026).

These studies compare scores across vulnerabilities at one point in time. The question asked here is different: given one container image and one week, how much exploitability exposure will it carry over the next four weeks. That framing makes the recent history of the same image a natural predictor, which is why persistence is the main baseline of this study (Section 4.3) and why a formula of the current EPSS and KEV values is a fair competitor for any learned model (Section 4.8).

## 2.4 Vulnerability risk in container and Kubernetes deployments

NIST's container security guide lists image vulnerabilities, registry hygiene, orchestrator configuration and runtime isolation as the main risk areas of containerised deployments Souppaya et al. (2017). Empirical studies of public images show how large the first of these is. Shu, Gu and Enck scanned Docker Hub images and found vulnerabilities in both official and community images, many of them inherited from the base images they build on Shu et al. (2017). Zerouali and co-authors related outdated packages in Debian-based images to the vulnerabilities and bugs they carry Zerouali et al. (2019). Mills, White and Legg followed 380 images across three scan periods and found that reported vulnerability counts rose despite regular updates, while fewer than one percent of the findings met their criteria for high real-world risk once attack vector and exploit availability were considered Mills et al. (2023). Kim, Park and Hong inspect the file system directly to catch packages that package-manager-based scanners miss Kim et al. (2025). On the orchestrator side, Rahman and co-authors identified eleven categories of security misconfiguration in 2,039 open-source Kubernetes manifests Rahman

et al. (2023), and Minna and co-authors examine the security implications of Kubernetes networking Minna et al. (2021). Our earlier Fuzzyfortify framework scored these conditions with expert-weighted fuzzy rules Hafiz Hersyah et al. (2025).

The image-scanning studies above count vulnerabilities; the finding of Mills and co-authors that few of them carry real-world risk is the reason this study weights each CVE by a runtime-reachability estimate $\rho$ and by exploitation evidence rather than by count or severity (Section 3.4). The misconfiguration and networking studies motivate the Kubernetes-exposure input $x_5$, which this study records as a static rubric value and does not yet derive from telemetry (Section 3.5). What none of these studies provides is a per-image, forward-looking measure of exploitability exposure built from sealed public evidence, which is the target defined in Section 3.4.

# 3 Methodology

## 3.1 Study design

The study has two parts that share a testbed. The main part trains HANFIS on weekly asset-level evidence from 120 container images and compares it with flat ANFIS variants and simple baselines under a protocol frozen before training (Sections 3.4 and 4.2), followed by one pre-registered forward evaluation (Section 3.6). The second part measures what Kubernetes observability costs, in ten counterbalanced ON–OFF run pairs of the same baseline workload (Section 3.3), so that resource use by the monitoring stack is not later mistaken for a change in workload exposure. Runtime telemetry is not a model input, and the environmental inputs are static per-asset values (Section 3.4). The original description of the overhead design is Supplementary note S12 of Additional file 1.

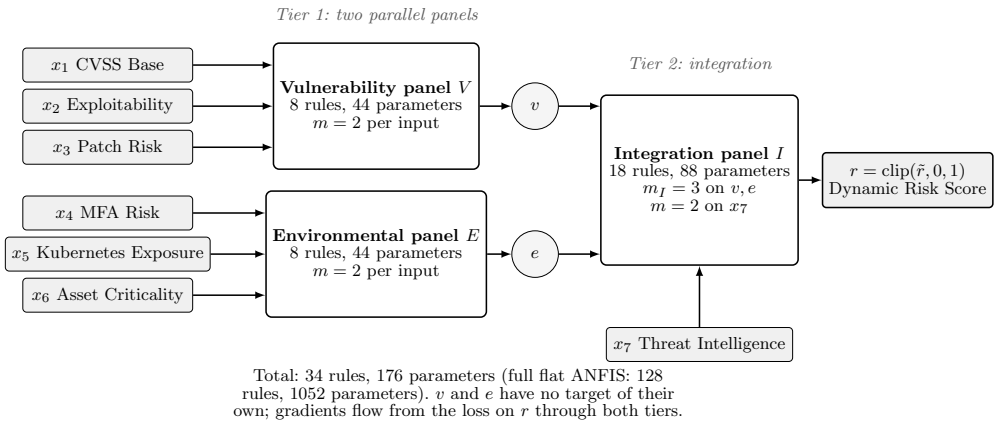



**Fig. 1** Structure of HANFIS. Two first-tier Sugeno panels, vulnerability $V$ and environmental $E$, produce the latent indices $v$ and $e$. An integration panel $I$ combines them with Threat Intelligence $x_7$ into the Dynamic Risk Score $r$. Rule and parameter counts per panel are those of Table 1.

## 3.2 HANFIS architecture and training

HANFIS composes three first-order Sugeno ANFIS panels. The vulnerability panel $V(x_1, x_2, x_3) \to v$ takes CVSS, Exploitability, and Patch Risk. The environmental panel $E(x_4, x_5, x_6) \to e$ takes MFA Risk, Kubernetes Exposure, and Asset Criticality. The integration panel $I(v, e, x_7) \to \tilde{r}$ takes the two intermediate indices and Threat Intelligence, and the final score is $r = \mathrm{clip}(\tilde{r}, 0, 1)$. No panel is given an intermediate target: $v$ and $e$ are latent, and gradients flow end-to-end from the loss on $r$ back through both tiers. Figure 1 shows the structure.

Each panel uses Gaussian membership functions,

$$\mu_{ij}(z_i) = \exp\left(-\frac{(z_i - c_{ij})^2}{2\sigma_{ij}^2}\right), \qquad i = 1, \ldots, n,\ j = 1, \ldots, m, \tag{3}$$

Sugeno-normalised firing strengths $\bar{w}_k = w_k / \sum_l w_l$ with $w_k = \prod_i \mu_{i,j_k(i)}(z_i)$, and first-order consequents $f_k(z) = \beta_{k0} + \sum_i \beta_{ki} z_i$, so that a panel's output is $\sum_k \bar{w}_k f_k(z)$. The raw inputs $x_1, \ldots, x_7$ each use $m = 2$ membership functions; the intermediate variables $v, e$ inside the integration panel use $m_I = 3$, so that $v$ and $e$ can carry the

categories {low, medium, high}, following the requirement that intermediate variables in a hierarchy stay semantically interpretable Lee et al. (2003); Section 4.10 shows that the trained centres of $v$ and $e$ do not always keep that order. A connected trapezoidal (Ruspini) membership family is available as an ablation alternative (Section 4.5).

Table 1 gives the resulting counts against a full flat ANFIS over the same seven inputs with $m = 2$ membership functions each; in the hierarchy, rule growth is linear in the number of panels, while in the flat model it is exponential in the number of inputs Raju et al. (1991); Wang (1998).

**Table 1** Rule and parameter counts by panel against a full flat ANFIS. $m = 2$ on the raw inputs and $m_I = 3$ on $v, e$; the flat ANFIS uses the same seven inputs.

| Panel | Inputs | Rules | Premise params. | Consequent params. | Total |
|---|---|---|---|---|---|
| $V$ | $x_1, x_2, x_3$ | 8 | 12 | 32 | 44 |
| $E$ | $x_4, x_5, x_6$ | 8 | 12 | 32 | 44 |
| $I$ | $v, e, x_7$ | 18 | 16 | 72 | 88 |
| HANFIS (total) | 7 raw + 2 intermediate | **34** | 40 | 136 | **176** |
| Flat ANFIS (reference) | 7 raw | 128 | 28 | 1024 | 1052 |

Consequent slopes in every panel are constrained non-negative through a softplus reparameterisation, so each rule's consequent is non-decreasing in every input under the higher-is-riskier convention. Intercepts stay free and rule weights are normalised, so $r$ itself is not guaranteed to be monotone, and monotonicity is checked empirically (Section 4.7). Training is hybrid: the integration panel's consequents are solved in closed form by ridge least squares every epoch,

$$\beta = (\Phi^\top \Phi + \lambda I)^{-1} \Phi^\top y, \qquad \lambda \geq 10^{-3}, \tag{4}$$

with $\Phi$ the per-rule design matrix $\bar{w}_k \cdot (1, z_1, \ldots, z_n)$, while Adam updates the premise parameters. The frozen alternating variant also solves both lower panels' consequents

in closed form every epoch: with the integration panel's firing weights and consequents frozen, the output is affine in $v$ and $e$ for each row and hence linear in the lower panels' consequents, so Adam trains only the premise parameters. Three pre-registered restarts with fixed seeds are trained per fold (patience 100 on validation loss, at least 200 epochs), and the restart with the lowest validation loss is kept. A pure end-to-end Adam variant without a closed-form step is kept as an ablation (Section 4.5), because it is unstable on some seeds.

### 3.3 Experimental platform and telemetry validation

The experimental workflow ran in Ubuntu 24.04 under Windows Subsystem for Linux 2 (WSL 2), with Docker Desktop as container runtime and Kubernetes integration. The testbed had two Ready nodes and a baseline application, P0, deployed with two ready replicas in the `hanfis-research` namespace; a load-generator pod reached P0 through an internal service, and status code 200 was required at every gate. The observability stack (Prometheus The Prometheus Authors (2026), Prometheus Operator, kube-state-metrics and node-exporter) ran in a separate `monitoring` namespace and was scaled to zero in the OFF condition, with the original definitions saved so that the ON state could be restored. Preparation followed a sequence of auditable gates with SHA-256 manifests (Table S1 of Additional file 1); the evidence that the gates were met is the set of archives for Runs 7–16.

The observability-overhead protocol, `external-v3.0`, has ten counterbalanced ON–OFF run pairs (Runs 7–16), a fail-closed admission rule under which a failed gate yields a `HOLD` decision and no observation, the run as the independent replication unit, an exact two-sided sign-flip test over the ten paired differences (smallest attainable $p$ of $2/2^{10} = 0.002$) and a 10,000-resample bootstrap Efron (1979) interval for the mean difference. Its full description, the overhead definitions and the validity safeguards are

in Supplementary note S8 of Additional file 1. The estimated increment is an instrumentation cost and is not read as a change in application exposure; runtime telemetry is not an input of the model (Section 3.5).

### 3.4 Realised exploitability-exposure target and real-world asset-week dataset

The environmental inputs $x_4$ to $x_6$ are static per-asset values recorded in the asset inventory. Input $x_5$ follows a written rubric over the cluster configuration (whether the asset accepts traffic from many pods, is scoped by a NetworkPolicy, or holds admission rights) and $x_6$ a written three-factor rubric. The runtime telemetry described above is not a model input, so the time variation of the score comes from the EPSS and KEV signals. The label used to train and evaluate HANFIS is constructed separately, from realised vulnerability outcomes rather than expert judgement. The observation unit is an asset-week: one digest-pinned container image $a$ observed at one Monday $t$. For a 30-day horizon $\Delta = 30$ discretised into four weekly checkpoints $T = \{t{+}7, t{+}14, t{+}21, t{+}28\}$,

$$y(a,t) = \frac{100}{|T|} \sum_{\tau \in T} \max_{v} \left[ X_v(\tau)\, S_{v,a}(\tau) \right], \tag{5}$$

$$\begin{aligned} X_v(\tau) &= \max\left(\mathrm{EPSS}_v(\tau), \mathbb{1}[v \in \mathrm{KEV}(\tau)]\right), \\ S_{v,a}(\tau) &= \rho_{v,a} \cdot \mathbb{1}[v \text{ affected and reachable on } a \text{ at } \tau], \end{aligned} \tag{6}$$

where $\rho_{v,a} \in \{0, 0.1, 0.25, 0.6, 1\}$ is a five-level runtime-reachability estimate (not installed; installed with no dependency; transitively loaded but inactive; loaded with an unproven trigger; loaded with a demonstrated trigger). $S$ uses $\rho$ rather than a bare indicator because otherwise the label saturates at 100 once any affected CVE enters KEV and the positive control described below would not differ between its two conditions. A CVE is treated as active for image $a$ at $\tau$ only if its publication date is $\leq \tau$

and its version-range status is `AFFECTED`, so no feature or label uses information not yet public at the time it purports to describe; $y$ is left unlabelled (feature-only) when $T$ extends beyond the last sealed evidence snapshot.

Evidence is sealed weekly: one EPSS bulk file per Monday and one CISA KEV catalogue Cybersecurity and Infrastructure Security Agency (2026) download, each stored byte-for-byte and hashed (SHA-256) into a manifest that a verification step rechecks before any build. This sealed 57 weekly snapshots (2025-08-25 to 2026-09-21) and a KEV catalogue of 1,728 entries. Each image contributes one frozen, digest-pinned Trivy Aqua Security (2026) vulnerability scan. CVEs lacking a publication date (a known Debian/Ubuntu-tracker gap) are dated by the first sealed weekly snapshot in which they are scored, and a CVE that never appears in any sealed snapshot is excluded from the active set rather than assumed absent. A positive control, P0-IF, isolates one asset with the image-filter Nginx module either inactive ($\rho = 0.25$: transitively present, unloaded) or active with its trigger path exercised ($\rho = 1$). It is built from the same digest-pinned base image as the primary asset P0, so its vulnerability surface (109 of 135 known CVEs as of the freeze date, 25 in `libexpat`) is not an artefact of an unrelated rebuild.

At the time of writing the inventory holds 120 assets (117 images across web, proxy, cache, database, queue, runtime, base, observability, and Kubernetes-native infrastructure and security tooling categories, plus P0 and the two P0-IF conditions) observed across the 57-week window. It comprises 6,833 asset-week rows, after excluding seven rows whose evidence remained unresolved (one CockroachDB CVE under Trivy status `under_investigation` at the inventory freeze date); the non-missing rate is 0.93, and no row is left in an unresolved evidence state. This clears the pre-registered data-quality gate: protocol frozen and dated; at least ten observations per model parameter (the gate is coded as $\geq 1{,}320$ rows, which is ten times the 132 parameters of the configuration with $m_I = 2$ that preceded the frozen $m_I = 3$ setting; the same rule gives

$\geq$ 1,760 rows for the 176-parameter configuration, and the inventory clears both); no leakage across the split described below; and every mandatory baseline runnable on the pilot. We treat the gate as a necessary condition for training HANFIS on real data, not as a result in itself. The three open decisions on label aggregation, label scale, and the definition of Patch Risk were closed by cross-checking the decomposition above against this subsection's own formula; they were not treated as free parameters. The row-wise maximum and the raw 0–100 scale are the definition as written, not a choice, and the {0,1,2} Patch Risk contract already matches the running pipeline. The 120-asset inventory described here is the final inventory used for every result in Section 4; no further scaling of the inventory is planned for this paper.

### 3.5 Relation of validated telemetry to HANFIS

The proposed risk model contains seven conceptual inputs arranged hierarchically (Section 3.2). Runtime telemetry is not an input of the model evaluated here: $x_5$ is a static rubric value (Section 3.4), and raw CPU, memory and latency measure resource use, not exposure. Deriving $x_5$ from runtime telemetry would require a mapping from raw measurements to an exposure score that is specified and pre-registered before any model evaluation, to avoid post hoc feature selection; we leave it as a separate hypothesis for future work.

Figure S1 of Additional file 1 summarises the relationship among infrastructure preparation, controlled telemetry acquisition, validation, and HANFIS. The figure is supplied as native LaTeX/TikZ so that it remains editable in the Springer manuscript.

### 3.6 Forward evaluation: pre-registered design

The confirmatory comparison and the post hoc analyses reported above use data whose labels were already known when the questions were asked. To obtain an evaluation that does not, we froze a forward-evaluation protocol before any label for the test

weeks was computed. The protocol, the five final HANFIS models (trained only on labelled weeks up to 2026-07-27, the first test week minus the 30-day embargo), the blend weight, the coefficients of the max-form formula of Section 4.8, and all analysis scripts were committed and tagged (`e7-prereg-2026-10-12`, created on 2026-10-12 at 15:04 +0700). A script verified that the tagged tree is identical to the working files. The evaluation script refuses to run unless this verification passes, and it runs only once. The protocol was also registered on the Open Science Framework before any forward label was computed (registration date 2026-10-13) Hersyah et al. (2026). The analyses E14c and E15 to E20 were run on earlier data after the freeze and before the registration; the registration lists E15 to E20 and does not list E14c.

The test weeks are the Mondays $t$ from 2026-08-31 with $t + 28$ days not later than the data date $D_2$ = 2026-11-02, six weeks in total; fewer than six matured weeks postpone the study rather than relax its criteria. Weekly EPSS and CISA KEV snapshots after 2026-09-21 are downloaded only after the tag, the vulnerability database is frozen once on $D_2$, and every image is rescanned with it. The predictors are HANFIS (mean of five seeds), persistence (the label of week $t - 4$), a fixed blend of the two ($\lambda = 0.5109$, fitted on out-of-fold predictions), and the formula. Skill scores against persistence use pooled mean squared error with a bootstrap clustered by image (2,000 resamples). Two families of one-sided hypotheses are tested, each with its own Holm correction Holm (1979) at $\alpha = 0.025$: whether HANFIS and the blend improve on persistence (P7a, P7b), and whether the formula improves on persistence while HANFIS is not better than the formula (P7e, P7f). The direction of predicted change is a secondary hypothesis (P7d). Rows with unresolved vulnerability-range evidence are dropped only if they amount to at most 2% of the test-week rows, and an asset that loses all of its test weeks leaves the analysis and is reported (`cockroachdb` was expected to, but no asset was dropped). The results are reported in Section 4.16.

## Use of AI tools

An AI assistant (Claude, Anthropic; the Claude Sonnet 5.5, Claude Opus 5.5 and Claude Fable 5.1 models, used through the Claude Code environment from September to November 2026) helped to write and test analysis and utility code, to draft the two unregistered protocols (Sections 4.15 and 4.9), to run scripts at the authors' direction, including the stages of the forward evaluation on the pre-registered date, to draft and revise manuscript text, including first drafts of parts of the Results and Discussion, and to check the reference list against doi.org. The authors decided every protocol, hypothesis and claim before the corresponding run, verified the code, the results and the references, reviewed and edited all text, and take full responsibility for the content. The assistant is not an author (see Declarations).

# 4 Results

## 4.1 Observability overhead

Ten counterbalanced run pairs passed every gate (Runs 7–16); one aborted attempt each of Run 7 and Run 17 failed the integrity gate and were recorded as incidents. Table S14 of Additional file 1 gives the paired differences. The resource cost of the stack is large and has the same direction in every pair: node CPU +99.36 mCPU (95% CI [96.29, 103.35], +43.3%) and node memory +280.76 MiB ([250.99, 303.54], +18.7%), of which the monitoring namespace itself accounts for only 39.79 mCPU and 204.19 MiB, so pod-level accounting understates the platform cost by a factor of about 2.5 (effect size $d_z = 16.5$ for node CPU); the remainder is induced platform work (kubelet, cAdvisor, container runtime and the API server). The cost does not reach the observed workload: median and P95 latency change by −0.005 ms ([−0.055, +0.044]) and +0.059 ms ([−0.126, +0.265]), below 3% of the baseline, and the P0 container

uses 0.334 MiB less memory under monitoring ($p = 0.016$), an effect of no practical size. The intervals bound the latency effect without establishing equivalence.

## 4.2 Training configuration

Throughout, "pre-registered" means that a dated protocol was committed to the project's version-controlled repository and tagged before the corresponding training run. This does not refer to an entry in an external registry, except for the forward evaluation (Section 3.6), which was also registered on the Open Science Framework. The confirmatory protocol was committed on 30 September 2026 and tagged the same day (tag `e4-prereg-2026-09-29`, whose name carries the nominal date of the protocol file). The tag covers the protocol, the seed list, the split code and the HANFIS model code. The parameter-matched flat comparator and the training script were committed on 30 September and 1 October 2026, after the tag but before the first confirmatory run on 1 October 2026 (109-asset inventory); the 120-asset run reported here took place on 2 October 2026. Later additions to the training script (saving models, recording the normalisation) do not change its predictions.

All results below use the frozen configuration (the protocol amendments that fixed each setting are listed in Table S17 of Additional file 1): hybrid closed-form/Adam training (Section 3.2), learning rate $10^{-2}$, ridge $10^{-3}$, three pre-registered restarts per fold with fixed seeds, patience 100 on validation loss with a minimum of 200 epochs, the Gaussian membership family with the monotonicity constraint active (justified in Section 4.5). Evaluation uses a grouped, embargoed temporal split (`GroupTimeSplit`). Images are assigned to $n$ held-out groups by a seeded permutation. Fold $k$ trains on every other group up to a cutoff date and evaluates group $k$ inside the following block of weeks, after a 30-day embargo equal to the outcome window. No image and no overlapping outcome window therefore appears on both sides of any fold, and every image is evaluated exactly once. On the completed 120-asset inventory this yields 5

folds of 95–96 training images against 23–24 held-out images. The alternating lower-panel closed-form training variant (Section 3.2) was verified against an independent closed-form derivation on synthetic data (mean squared error $0.78 \rightarrow 4 \times 10^{-4}$ over six alternating iterations with no premise training at all) before being adopted as the frozen training scheme, used throughout the real-data results reported below and in Section 4.4.

## 4.3 Predictive performance

Table 2 reports the mandatory baselines on the 6,357 labelled rows described in Section 3.4, pooled over all five test folds. Pooling gives one mean-squared-error ratio over every held-out row, instead of an average of per-fold ratios, which is unstable when a fold's reference error is near zero. $\mathrm{SS}_{\mathrm{clim}}$ and $\mathrm{SS}_{\mathrm{pers}}$ are skill scores against the training-fold climatology and against a causal 4-week persistence forecast, respectively.

**Table 2** Mandatory baselines, pooled over 5 grouped-temporal folds, raw label scale (0–100).

| Baseline | RMSE | $\mathrm{SS}_{\mathrm{clim}}$ | $\mathrm{SS}_{\mathrm{pers}}$ |
|---|---|---|---|
| Climatology | 4.010 | 0.000 | −37.78 |
| Single CVSS score | 3.537 | 0.222 | −29.17 |
| Persistence (causal, 4-week lag) | 0.644 | 0.974 | 0.000 |
| Ridge regression, all 7 inputs | 1.169 | 0.915 | −2.293 |

A single CVSS score explains a modest fraction of the label's variance ($\mathrm{SS}_{\mathrm{clim}} = 0.222$; about 0 on the earlier 27-image pilot), far below persistence or ridge. A persistence forecast recovers 97% of the climatology-relative skill, because the set of active CVEs and their EPSS scores change slowly from week to week. On the 120-asset inventory a ridge model over all seven inputs is substantially worse than persistence ($\mathrm{SS}_{\mathrm{pers}} = -2.293$, a reversal from the pilot's +0.301, on every one of the five folds; Section 5.1), consistent with a linear model over-extrapolating as the inventory grew

more heterogeneous. Persistence is therefore the bar that H1b and H1c (Section 1) ask HANFIS to clear or match. The comparisons H1a–H1c and H2/H3 (the last two tested together by the frozen protocol) are pre-registered with fixed seeds, fold assignment, a smallest effect size of interest of 5% on $SS_{pers}$, group-clustered bootstrap intervals and Holm correction over the family of four. Table 3 reports the outcome on the 120-asset inventory (Section 3.4): HANFIS confirms H1a, H1c and H2/H3, does not confirm H1b, and H2′ is reported as a capacity reference without a criterion. Fuzzy-fortify is not in the family: it needs four native inputs (complexity-resilience index, impact, base score, exploitability) that the asset-week data do not produce, and the comparison protocol forbids unreported proxy mappings.

**Table 3** Confirmatory results: HANFIS skill score against each comparator. Group-clustered bootstrap 95% CI, Holm-corrected across the four-hypothesis family.

| Hypothesis | Comparator | SS | 95% CI | Outcome |
|---|---|---|---|---|
| H1a | Single CVSS score | 0.967 | [0.951, 0.980] | Confirmed |
| H1b | Persistence (4-week) | 0.015 | [−0.607, 0.246] | Not confirmed |
| H1c | Ridge, 7 inputs | 0.696 | [0.527, 0.816] | Confirmed |
| H2/H3 | FlatANFISMatched | 0.665 | [0.269, 0.844] | Confirmed |
| H2′ | Flat ANFIS (full) | 0.253 | — | Reported, no criterion |

The H1a comparator, a single CVSS score, has no access to exploitability or the KEV indicator, the two inputs that carry HANFIS's skill (Section 4.8), and the H1c comparator, a ridge model on all seven inputs, is itself worse than persistence (Table 2).

H1b's confidence interval crosses zero, so HANFIS is not distinguishable from a causal 4-week persistence forecast. The E3 pilot showed the same pattern (Table 2): the strongly autocorrelated label remains the hardest bar in this study. The post hoc analysis in Section 4.5 indicates why: HANFIS outperforms persistence when the label moves and underperforms it when the label is stable.

The H2/H3 margin between two models with an identical 176-parameter budget is not uniform across folds. HANFIS wins on four of the five held-out blocks, with

per-fold skill against FlatANFISMatched from 0.165 to 0.924; fold 1 is negative (SS = −0.122), and in that fold the predicted variance of HANFIS exceeds the label's own variance by more than three orders of magnitude on several near-constant-label images (ratio > 1,000× in the most extreme case), consistent with under-damped day-to-day snapshot noise where the weekly aggregate carries little signal (Section 5.1).

FlatANFISMatched's held-out predictions range well outside the plausible label interval (−6.679 to 11.059, against 0.000 to 10.401 for HANFIS), consistent with poor extrapolation from unsupervised cluster centres that have no access to the vulnerability/environmental/threat grouping that HANFIS encodes by construction (Section 3.2). We read this as suggestive of the mechanism claimed in C1 and H2/H3 and not as an artefact of model selection: the random 15% validation carve-out used to select the best of three restarts is identical for both models, and the reported skill comes from the held-out block that the carve-out never touches.

### 4.4 Accuracy-complexity curve

The scalar bottleneck between the lower panels and the integration panel is a candidate explanation for any residual gap between HANFIS and a full-capacity flat ANFIS, because compressing $v$ and $e$ to one number each may discard cross-subsystem interaction. A sweep over the bottleneck width $k$ passes $k$-dimensional $v$ and $e$ into the integration panel. Under grid partitioning the integration rule count grows as $m_I^{2k} \cdot m$: at the frozen $m_I = 3$, $k = 1$ is HANFIS itself (34 rules, 176 parameters), $k = 2$ costs 178 rules and 1,152 parameters, and $k \geq 3$ exceeds 1,400 rules, more parameters than the inventory has rows (Figure 2). The sweep script refuses such settings, so we ran $k \in \{1, 2\}$. At $k$=1 the sweep reproduces the frozen training scheme; a per-row comparison on the earlier 109-asset inventory gave Pearson $r = 0.9984$ against the confirmatory predictions over 981 held-out rows. Supplementary note S11 of Additional

file 1 holds the full account, including an earlier, confounded version of the sweep that the numbers here supersede.

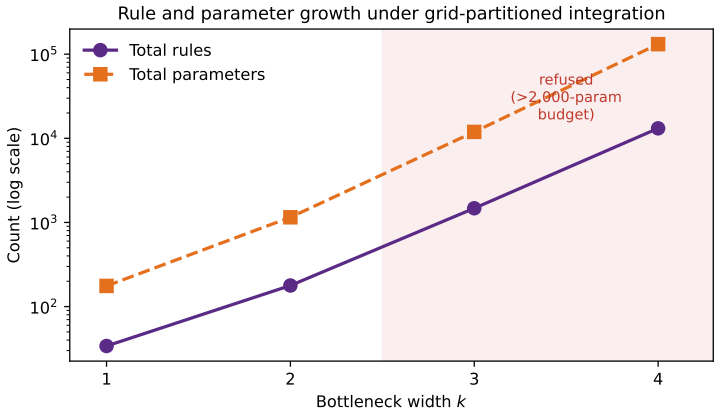



**Fig. 2** Rule and parameter growth with bottleneck width $k$. Grid partition of the integration tier; the shaded region ($k \geq 3$) exceeds the parameter budget the present inventory supports and was refused.

**Table 4** Bottleneck-width sweep: pooled RMSE and skill against persistence. 95% confidence intervals from 2,000 image-clustered bootstrap resamples (the same procedure as Table 3), 120-asset inventory.

| $k$ | Rules / Params | RMSE (pooled) | $\mathrm{SS}_{\mathrm{pers}}$ [95% CI] |
|---|---|---|---|
| 1 | 34 / 176 | 0.587 | 0.169 [−0.330, 0.343] |
| 2 | 178 / 1152 | 0.820 | −0.622 [−2.259, −0.100] |

$k$=1 recovers skill consistent with the H1b result (Table 3: $\mathrm{SS}_{\mathrm{pers}} = 0.015$, $[-0.607, 0.246]$); both intervals cross zero. $k$=2 is worse than persistence, with an interval entirely below zero. The paired difference on matched resamples, $\mathrm{SS}_{\mathrm{pers}}(k{=}1) - \mathrm{SS}_{\mathrm{pers}}(k{=}2) = 0.791$ (95% CI $[0.354, 2.037]$), excludes zero, and $k$=1 has the lower pooled RMSE on all five folds (two-sided sign test $p = 0.0625$, the floor with five folds; Figure S5 of Additional file 1). This is a mechanism claim rather than proof that wider bottlenecks are intrinsically worse: every $k$=2 fold falls below ten observations

per parameter (range 0.3–2.9), while $k$=1 clears that threshold in three of five folds. Disabling the hard clamp on $v, e$ costs $k$=1 0.161 of skill and $k$=2 0.813, consistent with $v, e$ being estimated less reliably once six times as many consequent parameters compete for the same rows. Separating an intrinsic cost of wider bottlenecks from this data-scale effect needs an inventory far larger than 120 assets.

## 4.5 Ablation and robustness analysis

Table S2 of Additional file 1 reports the membership-family×monotonicity ablation (E1) on two synthetic scenarios (S1 smooth, S2 with a hard threshold; five seeds per cell). The monotonicity constraint costs little on the smooth scenario but is expensive on the threshold scenario for the Gaussian family (RMSE 0.117 → 6.067), because softplus-constrained slopes cannot represent a local reversal; the connected Ruspini family degrades far less (0.646 → 2.126). The frozen protocol therefore keeps the Gaussian family with monotonicity active as the frozen default and treats Ruspini as a documented, cheaper fallback. An end-to-end pure-Adam variant without the closed-form anchor (Section 3.2) diverged on a subset of seeds, confirming that the hybrid scheme is necessary.

*Sensitivity to the EPSS model change.* The EPSS scoring model changed version on 2026-06-15 (`v2025.03.14` to `v2026.06.15`). In a post hoc sensitivity analysis, the confirmatory pipeline was re-run on the 4,560 asset-weeks whose labels all pre-date the change (720 held-out rows; Table S3 of Additional file 1). H1a, H1c and H2/H3 remain confirmed, and H1b remains unconfirmed, with a much wider interval.

*Where HANFIS and persistence differ.* The pooled skill against persistence (0.015) hides two regimes (exploratory, post hoc, outside the Holm-corrected family). For the four weeks in which the label is fully computed under the new EPSS model while the lagged label is still computed under the old one (2026-W24 to W27; 95 rows), skill against persistence is +0.483; on the remaining 985 rows it is −0.420. HANFIS

is therefore reactive rather than predictive: better than persistence when the label moves, worse when it does not. Two further observations qualify H2/H3. The first held-out fold, trained on 2.2 observations per parameter, contributes 91% of the pooled gap to the matched model; without it the skill against FlatANFISMatched is 0.183 and against the full flat model 0.084. The fold-by-fold and week-by-week values are in Supplementary note S2 of Additional file 1.

## 4.6 Explanation fidelity

We tested whether the rule-level explanation that HANFIS exposes is faithful to its inference, using the 25 saved models (five folds × five seeds), which reproduce the confirmatory predictions exactly. The run is reported as a documented deviation, because the version-control freeze preceded the commit that contained the protocol text. The rule-attribution check failed its criterion: removing the three rules ranked highest by attribution changed the output 4.1 times more than removing three random rules, but exceeded the median random removal in only 83.5% of non-degenerate rows (criterion: 90%); 552 of the 575 positive-control pairs increased strictly. We therefore do not claim validated rule-level explanations. The rule trace matches the inference and the direction of the response is verified, but the attribution of the output to individual rules is faithful on average and not uniformly (Table S4 and Supplementary note S3 of Additional file 1).

## 4.7 Attribution and monotonicity checks

We computed exact interventional Shapley values Shapley (1953) for the seven inputs of the 25 saved models (5,400 model–row pairs; a background of 60 random labelled rows, excluding P0 and P0-IF and identical for all models; the efficiency property holds to $2 \times 10^{-14}$). Exploitability ($x_2$) and the KEV indicator ($x_7$), both ingredients of the label, carry 78.9% of the mean absolute attribution; the three environment inputs

($x_4$–$x_6$) carry 3.3% (Table 5). The ranking is stable across models (Kendall $W = 0.79$; $x_2$ is the top input in 21 of 25 models), and in the 20% of rows with the highest label $x_7$ alone carries 63.0%. This quantifies the overlap between label and inputs discussed in Section 5: the model largely forecasts exploitability signals it can already see, and the label contains no environment component by construction.

**Table 5** Exact Shapley attribution and within-row monotonicity checks (post hoc). Five-seed ensemble, descriptive. "Falls" is the share of steps, over the range observed in the data, in which the score drops by more than 0.05 points when one input is raised and the others are held fixed. Share: mean absolute attribution; Max drop and Range: largest fall and mean end-to-end change of the score in points.

| Input | Share (%) | Falls (%) | Max drop | Range |
|---|---|---|---|---|
| $x_1$ CVSS | 10.9 | 1.7 | 2.46 | 1.99 |
| $x_2$ Exploitability | 46.4 | 1.2 | 0.21 | 6.53 |
| $x_3$ Patch Risk | 6.8 | 24.8 | 2.28 | 1.11 |
| $x_4$ MFA Risk | 1.1 | 29.1 | 0.46 | 0.09 |
| $x_5$ Kubernetes Exposure | 1.3 | 34.8 | 0.60 | 0.14 |
| $x_6$ Asset Criticality | 0.9 | 10.5 | 0.40 | 0.13 |
| $x_7$ Threat Intelligence (KEV) | 32.5 | 1.2 | 0.33 | 6.45 |

Non-negative rule slopes do not guarantee a monotone score, because rule weights are normalised and intercepts are free. We therefore varied one input at a time over 11 points spanning the observed range (observed values for discrete inputs, quantiles from 1% to 99% otherwise) for the five-seed ensemble that is reported in Section 4. For the dominant drivers the share of falling steps is small ($x_1$ 1.7%, $x_2$ 1.2%, $x_7$ 1.2%), whereas for patch risk and the environment inputs it is 10–35%, although the environment inputs move the score by less than 0.15 points on average (Table 5). Individual seeds are less well behaved than the ensemble: the largest single drop (11.6 points, CVSS) occurs in one seed on two assets in the last held-out block, after the EPSS model change. We therefore present monotonicity as an empirical property of the dominant inputs, not as a guarantee of the architecture.

### 4.8 Label-ingredient ablation and information-minimal baselines

Both analyses were designed after the attribution results of Section 4.7 and are post hoc. In E9 we retrained HANFIS with $x_2$ and $x_7$ replaced by zero in training and test data, on the folds, seeds, embargo, validation split and hyperparameters of the confirmatory run (the same 1,080 held-out rows). Skill scores are $\mathrm{SS} = 1 - \mathrm{MSE}_{\mathrm{model}}/\mathrm{MSE}_{\mathrm{reference}}$ with 95% bootstrap intervals clustered by image (2,000 resamples). Without the two label ingredients the five-seed ensemble has a mean squared error of 14.23, against 0.41 with them and 12.54 for a single CVSS score; its skill over CVSS is $-0.135$ ($[-0.336, 0.046]$) and over a ridge model on the remaining five inputs $-0.070$ ($[-0.250, 0.096]$), and that ridge model is itself no better than CVSS ($-0.061$, $[-0.130, 0.006]$). On this inventory the remaining inputs carry no demonstrable information beyond CVSS.

In E10 we compared the confirmatory HANFIS predictions with the simplest functions of those inputs trained on the same rows: a plug-in $100\,x_2$, ridge regression on $(x_2, x_7)$, and gradient boosting on $(x_2, x_7)$, on all seven inputs, and on the seven inputs plus the four-week lag of the label (Table 6). HANFIS has a lower error than every alternative with an interval excluding zero, except gradient boosting restricted to $x_2$ and $x_7$ (skill 0.606, $[-0.079, 0.847]$). Adding the other inputs makes boosting worse, and models that receive the lagged label as a feature do much worse than the lag itself, which we attribute, without having tested it, to distribution shift between training and test periods.

In E11 we asked whether a small formula suffices. Because the label is the window mean of a maximum over $\max(\mathrm{EPSS}, \nVdash[\mathrm{KEV}])\,\rho$, we fitted $\hat{y} = a + b\,\max(x_2,\, c\,x_7)$ on the training rows of each fold ($c$ on a grid, $a, b$ by least squares), together with a ridge model with the $x_2 x_7$ interaction and monotone gradient boosting on $(x_2, x_7)$. The grid selected $c = 0.10$ in all five folds, with $b$ between 99.2 and 100.0 and $a <$

0.07: almost exactly $100 \max(x_2,\, 0.1\, x_7)$. This formula has a lower pooled error (0.27) than HANFIS (0.41) and than persistence (0.42). HANFIS is worse than the formula (skill −0.534, [−1.438, −0.208]) and than the interaction ridge (−0.529), and not distinguishable from monotone boosting (0.538, [−0.005, 0.802]). We had expected parity or an advantage for HANFIS. On this target the 176-parameter model adds no accuracy to what a four-parameter formula of current EPSS and KEV signals provides, so the confirmatory gains over CVSS, linear models and a flat ANFIS show that the task is nearly determined by those two signals rather than that the hierarchy helps.

**Table 6** Label-ingredient ablation, information-minimal baselines and formula baselines. 1,080 held-out rows; skill score with 95% image-clustered bootstrap interval; MSE of the model and of the reference.

| Comparison | Skill | 95% interval | MSE |
|---|---|---|---|
| *E9: HANFIS retrained without $x_2$ and $x_7$* | | | |
| vs. CVSS only | −0.135 | [−0.336, 0.046] | 14.23 / 12.54 |
| vs. ridge, remaining five inputs | −0.070 | [−0.250, 0.096] | 14.23 / 13.30 |
| vs. HANFIS with all inputs | −33.8 | [−56.5, −22.5] | 14.23 / 0.41 |
| Ridge, five inputs, vs. CVSS only | −0.061 | [−0.130, 0.006] | 13.30 / 12.54 |
| *E10: HANFIS with all inputs vs.* | | | |
| Plug-in $100\, x_2$ | 0.859 | [0.672, 0.931] | 0.41 / 2.89 |
| Ridge on $(x_2, x_7)$ | 0.693 | [0.518, 0.817] | 0.41 / 1.33 |
| Ridge on lag-4 label, $x_2$, $x_7$ | 0.635 | [0.399, 0.781] | 0.41 / 1.12 |
| Boosting on $(x_2, x_7)$ | 0.606 | [−0.079, 0.847] | 0.41 / 1.04 |
| Boosting on seven inputs | 0.659 | [0.133, 0.860] | 0.41 / 1.20 |
| Boosting on lag-4 label and inputs | 0.653 | [0.104, 0.858] | 0.41 / 1.18 |
| Persistence (lag-4 label) | 0.015 | [−0.620, 0.243] | 0.41 / 0.42 |
| *E11: HANFIS with all inputs vs.* | | | |
| Max-form formula $a + b \max(x_2, c\, x_7)$ | −0.534 | [−1.438, −0.208] | 0.41 / 0.27 |
| Ridge on $x_2$, $x_7$, $x_2 x_7$ | −0.529 | [−1.415, −0.206] | 0.41 / 0.27 |
| Monotone boosting on $(x_2, x_7)$ | 0.538 | [−0.005, 0.802] | 0.41 / 0.88 |

## 4.9 Threat-intelligence ablation

H4 asks whether including the time-varying threat input improves prioritisation compared with an otherwise identical HANFIS without it. The registered protocols contain no test of H4, and E9 removes $x_2$ and $x_7$ together. After the forward evaluation we

therefore ran the closest procedure (protocol `e26-protocol-2026-11-07`; post hoc, descriptive, unregistered, no forward data): HANFIS was retrained with only $x_7$, the KEV indicator, set to zero, on the E4-bis folds, seeds, embargo and hyperparameters of E9. Without $x_7$ the pooled mean squared error rose from 0.41 to 3.16 (skill against the full model −6.738, 95% CI −13.958 to −2.899), in all five folds. The weekly ranking also fell: the Spearman correlation from 0.969 to 0.889 (difference −0.080, −0.089 to −0.072) and the precision at the top 20% from 0.973 to 0.716 (−0.258, −0.307 to −0.204). Without $x_7$, HANFIS still beat the CVSS-only baseline (skill +0.748, +0.605 to +0.856) but was far behind persistence (−6.625, −19.375 to −2.492). In the direction that H4 predicts, then, removing $x_7$ hurts. The reading is limited: $x_7$ is the KEV indicator, an ingredient of the label (Section 4.7), so the result measures the dependence of the model on a label ingredient, not the value of $x_7$ as an independent threat signal, and H4 as registered remains untested.

## 4.10 Trained rules and membership order

To document the rule base we printed the 34 rules of one model fixed beforehand (fold 0, first frozen seed) with the accessors of the model itself (Tables S11 to S13 of Additional file 1); the output of each panel rebuilt from these parameters equals the forward pass of the model on 1,000 fixed rows. Figure S4 of Additional file 1 shows the response of the five-seed ensemble of fold 0 over $(x_2, x_7)$: it rises smoothly in both inputs, and the response to $x_2$ saturates inside the observed range. The Gaussian centres are free parameters, and nothing forces them to keep the order of their index. In the documented model the centres of $x_2$, $v$ and $e$ are not in index order. Reading the parameters of all 25 saved models (an extension beyond the protocol, descriptive, no training), the centres are in increasing order for $x_1$, $x_3$, $x_4$, $x_5$ and $x_6$ in all 25 models, for $x_2$ in 24 and for $x_7$ in 20, but for the intermediate variables in only 8 models for $v$ and 17 for $e$. The names “low, medium, high” therefore cannot be read

from the membership index of the intermediate variables in most trained models, although Section 3.2 chose three functions for them to keep that reading. The rule base is printable and its structure is fixed, but the meaning of its intermediate terms has to be recovered for each trained model.

## 4.11 Horizon sweep

To check whether the conclusions depend on the four-week label window, we rebuilt the labels with windows of 58 and 86 days (eight and twelve weekly snapshots), set the persistence lag and the embargo to the window length, and repeated the out-of-fold comparison with the same folds, seeds and hyperparameters (post hoc; 889 and 697 rows; only skill scores are comparable across horizons). The formula keeps its advantage over persistence (skill 0.36, 0.49 and 0.44 at four, eight and twelve weeks). The gap between HANFIS and the formula closes with the horizon: $-0.534$ (interval $[-1.438, -0.208]$), $-0.048$ ($[-0.205, 0.032]$) and 0.039 ($[-0.031, 0.110]$). Longer windows contain only older weeks, so horizon and period are confounded; on the 408 asset-weeks present at all three horizons the change in the skill of HANFIS against the formula is $+0.862$ ($[+0.309, +2.973]$), while the skill of the formula against persistence does not change. Without exploitability and the KEV indicator HANFIS has no skill over CVSS at any horizon ($-0.099$ and $-0.179$ at eight and twelve weeks). Section 4.13 shows that the narrowing comes largely from weeks around the EPSS model change. The full results are in Table S15 and Supplementary note S9 of Additional file 1.

## 4.12 Prioritisation utility

Because risk scores are used to rank assets, we also compared the predictors on weekly ranking (post hoc; out-of-fold predictions at three horizons; weekly Spearman correlation and precision at the top 20%; Tables S5 and S6 and Supplementary note S4 of Additional file 1). All predictors rank assets almost identically. At four weeks the weekly Spearman correlation is 0.99 for the formula and for persistence and 0.97 for

HANFIS, and the precision at the top 20% is 0.97 for all three, so the lower squared error of the formula brings no practical gain in prioritisation. With eighteen paired comparisons and no correction for multiplicity, the intervals are descriptive.

## 4.13 Error anatomy and the EPSS model change

To see where the pooled differences come from, we analysed the four-week out-of-fold predictions by input-change stratum and by distance to the change of the EPSS model on 2026-06-15 (post hoc; bootstrap clustered by image; Tables S7 and S16 and Supplementary note S10 of Additional file 1). The advantage of the formula over persistence sits in the 628 of 1,080 rows in which an input changed during the previous four weeks (skill 0.400, interval 0.308 to 0.487) and vanishes where nothing changed (0.002). HANFIS has skill 0.125 in changed rows and −0.900 (−4.171 to −0.206) in unchanged rows: it adds noise where persistence already suffices. The largest errors fall in the weeks 2026-W21 to W24, whose label windows straddle the model change; these 190 rows hold 77% of the squared error of persistence and of the formula and 49% of that of HANFIS. On the remaining 890 rows the formula keeps its point estimate against persistence (0.348 against 0.357, interval now −0.060 to 0.422), whereas HANFIS is worse than persistence (−1.228) and than the formula (−2.418). On unaffected rows at eight and twelve weeks HANFIS stays behind the formula (−0.324 and −0.362, intervals including zero), so the deficit shrinks with the horizon without closing. The forward evaluation (Section 4.16) is free of this change.

## 4.14 Calibration

Calibration was checked after the registration of the forward evaluation had become public (post hoc, descriptive, no training; Table S8 and Supplementary note S6 of Additional file 1). All three predictors lie close to the identity line. Persistence runs low on all rows (mean error −0.097, interval −0.196 to −0.013), almost entirely because

of the weeks around the EPSS model change (on unaffected rows −0.015, −0.079 to 0.025). HANFIS departs most, with slope 1.025 (1.008 to 1.044) on all rows and, on unaffected rows, slope 1.031 (1.014 to 1.053) and intercept −0.193 (−0.300 to −0.085); these departures are small next to the label scale. A cross-fitted linear recalibration does not close the gap to the formula (skill of HANFIS against the formula −0.534, −1.383 to −0.204, before and −0.535, −1.287 to −0.232, after), and stacking finds no information in HANFIS that a straight line can use (skill of the combination against the recalibrated formula −0.001, −0.006 to 0.004).

## 4.15 Computational cost against flat ANFIS variants

The introduction and H2 promise a cost comparison that the confirmatory protocol did not contain. We therefore measured, after the forward evaluation and without using any of its data, the training time, peak memory, single-row inference latency and batch throughput of the frozen E4-bis procedures of HANFIS, FlatANFISMatched and the full flat ANFIS. The protocol was written and tagged before the measurement (`e25-protocol-2026-11-07`). The measurement ran once (five folds, three repetitions, the first frozen seed, one thread, CPU only, one mini PC under WSL 2) and is descriptive and unregistered. Table 7 sets it beside the accuracy results of Section 4.3; per-fold values are in Table S9 of Additional file 1.

Relative to the full flat ANFIS, HANFIS has about six times fewer parameters, about a tenth of the peak memory increase during training (0.40 against 3.83 MiB, lower in all five folds) and higher batch throughput (higher in all five folds). It was not faster to train (median 8.51 against 7.30 s, lower in two of five folds), and its single-row latency was about four times higher (398 against 96 $\mu$s). FlatANFISMatched, with the same parameter budget, trained about nine times faster and answered about eight times faster per row, while its memory increase grew with the number of training rows (5.5 to 663 MiB from fold 0 to fold 4), probably because of its cluster-radius search,

**Table 7** HANFIS against the two flat ANFIS variants. The accuracy rows come from the confirmatory E4-bis comparison (registered for FlatANFISMatched, reported without criterion for the full model; the fold-0 row is post hoc). The cost rows are the unregistered E25 measurement (median of 15 runs, first frozen seed, one machine). Flat ANFIS variants were not part of the forward evaluation.

| | Flat ANFIS (full) | FlatANFISMatched | HANFIS |
|---|---|---|---|
| Rules / parameters | 128 / 1,052 | 8 / 176 | 34 / 176 |
| Skill of HANFIS against the model | 0.253 (no criterion) | 0.665 [0.269, 0.844] (H2/H3) | — |
| The same without fold 0 (post hoc) | 0.084 | 0.183 | — |
| Range of held-out predictions | not reported | −6.679 to 11.059 | 0.000 to 10.401 |
| Training time, median (s) | 7.30 | 0.95 | 8.51 |
| Peak memory increase, median (MiB) | 3.83 | 194.13 | 0.40 |
| Single-row latency, median ($\mu$s) | 95.6 | 49.1 | 398.2 |
| Batch throughput, median (rows/s) | 264,865 | 2,456,989 | 388,665 |

which we did not test. The part of H2 that promised lower training time and latency is therefore not supported.

The measurement uses one seed; HANFIS training time includes three restarts whereas the full flat model is trained once with a different patience; latency includes the NumPy-to-PyTorch conversion and three unoptimised panel passes; memory is a process-level peak with about 1 MiB resolution; the machine is not an edge device; and no forward comparison with the flat variants exists.

## 4.16 Forward evaluation: results

The design of Section 3.6 was executed once on 2026-11-02, and no stage was repeated. The evaluation covers 6 forward weeks (2026-08-31 to 2026-10-05) and 720 asset-weeks from 120 images (119 image groups). No row was dropped under the pre-registered insufficient-evidence rule, so every asset stayed in the analysis, including `cockroachdb`. The EPSS model version stayed at v2026.06.15 throughout.

Table 8 lists the registered decisions. In weeks without an EPSS model change, HANFIS was not better than persistence (SS −3.757, 95% CI −9.177 to −1.594; the upper bound lies below the margin of 0.05, so P7a is supported). The fixed blend was worse than persistence (SS −0.807, −2.507 to −0.160; P7b). The max-form formula

beat persistence (SS 0.340, 0.060 to 0.628; MSE 0.261 against 0.396; one-sided $p = 0.0005$ against a Holm threshold of 0.0125; P7e confirmed), and HANFIS was not better than the formula (SS −6.208, −13.677 to −3.188; MSE 1.884 against 0.261; P7f supported). The mean weekly Spearman correlation between predicted and realised change was 0.066 (lower 95% bound −0.074), so P7d is not demonstrated. A bootstrap clustered by week (6 weeks) gives the same decisions (P7e: SS 0.340, 0.100 to 0.758). The reported $p$ values equal 1/2001, the smallest a bootstrap of 2,000 resamples can give.

**Table 8** Forward evaluation: registered decisions. Skill score (pooled mean squared error, bootstrap clustered by image, 2,000 resamples) with 95% CI. P7a and P7b form one Holm family, P7e and P7f another; P7e and P7f are post hoc in origin.

| Hypothesis | Comparison | SS | 95% CI | Decision |
|---|---|---|---|---|
| P7a | HANFIS against persistence | −3.757 | [−9.177, −1.594] | Supported (not better) |
| P7b | Blend against persistence | −0.807 | [−2.507, −0.160] | Worse |
| P7e | Formula against persistence | 0.340 | [0.060, 0.628] | Confirmed |
| P7f | HANFIS against formula | −6.208 | [−13.677, −3.188] | Supported (not better) |

Against the out-of-fold results of Section 4.8, where the MSE was 0.27 for the formula, 0.42 for persistence and 0.41 for HANFIS, the forward MSE of the formula (0.261) and of persistence (0.396) stayed close, while that of HANFIS rose to 1.884.

P7e and P7f have a post hoc origin: they were added to the protocol before the freeze but derive from analyses of earlier data (E11 to E14). The protocol is tagged `e7-prereg-2026-10-12` (commit `dbed812`) and registered on the Open Science Framework Hersyah et al. (2026); the forward outputs are tagged `e7-results-2026-11-02`. This is one forward window of six weeks and 120 images with shared weekly shocks, so the result does not extend to other EPSS model versions or to other image sets. Analyses after the freeze (E14c and E15 to E24) are post hoc and descriptive; none of them changes a registered decision.

# 5 Discussion

For a practitioner who needs to rank vulnerabilities by near-term exploitability exposure today, the evidence supports a simple choice: the max-form formula of the EPSS and KEV signals, with persistence as the comparator that any alternative must beat. HANFIS remains relevant only where an auditable rule structure is required and where an outcome that depends on the environment is available to test the environmental panel.

Three findings shape how the confirmatory comparison (Section 4.3) should be read. First, the label is dominated by its own recent history: a 4-week persistence forecast removes 97% of the error relative to climatology (Table 2; 96% on the earlier pilot), so any claim that HANFIS "predicts risk" is a claim about improving on a strong autoregressive baseline, which is why H1 is framed against persistence rather than against Fuzzyfortify or CVSS alone (Section 1). Second, a single CVSS score explains little of the realised 30-day exploitability exposure ($SS_{clim} = 0.222$; about 0 on the earlier pilot): severity and realised exploitation are different quantities, and conflating them is a plausible source of alert fatigue, the gap that C3 addresses. Third, the monotonicity constraint that keeps the model auditable (higher risk factors must not lower the score) has a family-dependent accuracy cost on data containing thresholds; Gaussian membership functions with monotonicity active trade some accuracy for a response that, for the dominant inputs, rarely falls as they rise (Section 4.7).

The post hoc analyses (Sections 4.7 and 4.8) narrow what these findings support. Exact Shapley attribution places 78.9% of the attribution on exploitability and the KEV indicator, both ingredients of the label, and 3.3% on the three environmental inputs; without those two inputs the model has no demonstrable skill over a single CVSS score. A 34-rule hierarchical model therefore estimates near-term exploitability exposure from current EPSS and KEV signals about as accurately as a persistence forecast that needs past labels, more accurately than generic linear and boosted

models, and less accurately than a four-parameter formula of the same two signals (Section 4.8), which with the interaction ridge has the lowest error of all predictors at the four-week horizon. At eight and twelve weeks the gap narrows only through weeks around the EPSS model change (Sections 4.11 and 4.13), and all predictors rank assets almost identically at four weeks (Section 4.12). The data do not show that the vulnerability–environment decomposition or the environmental inputs improve prediction, and this inventory cannot show it: the target depends on EPSS, KEV and reachability alone, so a benefit of the environmental inputs, if one exists, needs an outcome that depends on the environment, such as incident or impact data. The forward weeks agree (Section 4.16): the formula matched or beat the trained model, HANFIS was not better than persistence (P7a), and its blend with persistence was worse than persistence alone (P7b). We did not test why the trained model transferred worse than the formula. Two candidates are visible in the earlier data and remain untested: the model adds noise in rows in which no input changed (Section 4.13), and its prediction variance exceeds the label variance on near-constant images (Section 4.3); a four-parameter formula can do neither. The rule base can be printed (Tables S11 to S13 of Additional file 1), but the linguistic labels of its intermediate variables cannot be read from the membership index in most trained models (Section 4.10), so its readability is a property of its structure and not of its terms.

The observability-overhead runs (Section 4.1) support a separate, narrower claim: the monitoring stack is a fixed resource cost (node CPU +99.36 mCPU, of which the monitoring namespace accounts for 39.79) with no detectable effect on workload latency, so a later use of runtime telemetry to derive the Kubernetes-exposure input would not have to correct for the act of observing. Whether that input improves prediction is a separate question, and on the present inventory the environmental inputs add no demonstrable information (Section 4.8).

## 5.1 Limitations

Two limits of construct validity come first. First, the label and two of the inputs share ingredients: $x_2$ (EPSS $\times \rho$) and $x_7$ (the KEV indicator) are the values at $t$ of quantities that the label aggregates over $t{+}7, \ldots, t{+}28$, and runtime reachability $\rho$ enters both. The task is therefore to forecast the near future of exploitability signals that the model can already see, not to predict independent compromise outcomes, for which no ground truth exists here. The persistence baseline, built in the same way, is the relevant bar, and the comparison with a single CVSS score should be read in that light. The exact Shapley attribution (Section 4.7) and the ablation without these two inputs (Section 4.8) show how heavily the model's skill rests on them. Second, the dynamic character of the score comes from the time-varying EPSS and KEV feeds and from runtime reachability. Runtime telemetry (CPU, memory, latency) is used only to quantify observability overhead and is not a model input, so "dynamic" must not be read as telemetry-driven scoring. The rule-level attribution is faithful on average but not uniformly (Section 4.6), and we do not claim validated explanations.

All analyses labelled post hoc were designed after the confirmatory results and run on the same data; they are descriptive, carry no multiplicity correction, and none of them changes a registered decision. The cost measurement (E25), the $x_7$ ablation (E26) and the rule documentation (E27) were run after the forward evaluation, use no forward data, and are unregistered.

The inventory consists of public container images and a small number of testbed assets built from a public base image, and the label reflects exploitation signals of public vulnerabilities (EPSS, KEV), not incidents in a specific organisation; generalisation to other workloads or to incident-based outcomes is untested.

Three data-related caveats are detailed in Supplementary note S7 of Additional file 1. On the 120-asset inventory (6,357 labelled rows; Table 2), a linear ridge model

over all seven inputs underperforms persistence on every one of the five grouped-temporal folds ($SS_{pers} = -2.293$ pooled, raw scale), and we did not test why. The EPSS scoring model changed version (`v2025.03.14` to `v2026.06.15`) inside the sealed 57-week window, a threat to label comparability; a post hoc re-analysis restricted to weeks whose labels all pre-date the change leaves the confirmatory conclusions unchanged (Section 4.5). The data-sufficiency gate (at least ten observations per parameter) is met by the pooled sample (6,357 labelled rows against 176 parameters) but not by the two earliest held-out folds (2.2 and 7.1 observations per parameter), which are also those in which HANFIS is furthest behind persistence; The H2/H3 pooled margin is dominated by the first fold (Section 4.5).

CVEs lacking a Trivy-reported publication date are dated by their first appearance in a sealed EPSS snapshot (at most 7 days late), and a single CVE whose Trivy status lies outside the accepted set makes the whole asset-week unusable; this affected one of the 120 images for seven consecutive weeks from 2026-08-10, and such rows are removed. Labels whose four-week window straddles the EPSS model change of 2026-06-15 (and the persistence labels derived from them) mix two score definitions; these rows (18% of the out-of-fold rows) hold 77% of the squared error of persistence and of the formula, and the forward evaluation avoids them. The label aggregation rule, its numeric scale and the definition of Patch Risk were closed and pre-registered before the confirmatory comparison in Table 3 was run.

The testbed is a single two-node WSL 2/Docker Desktop Kubernetes cluster; external validity to production multi-node clusters and other CNI/storage stacks is untested. Ten paired observability runs, while showing large and consistent effects, still provide limited power for null-hypothesis testing on the latency measure specifically, which is why the reported confidence intervals rather than a significance threshold carry the interpretive weight in Section 4.1.

# 6 Conclusion and Future Work

This paper asked whether a domain-informed hierarchical ANFIS earns its complexity when scoring the near-term exploitability exposure of container images. On this target it does not. HANFIS reduces a 128-rule, 1,052-parameter flat Sugeno system over seven cloud-native risk inputs to 34 rules and 176 parameters (Section 3.2) by separating vulnerability and environmental reasoning into two first-tier panels before an integration tier combines them with dynamic threat intelligence. Under a protocol frozen and dated before training began (Table 3), it confirms a substantial reduction in estimation error against a single CVSS score (H1a), a linear model over the same seven inputs (H1c), and a parameter-matched flat ANFIS initialised by subtractive clustering (H2/H3). It is not distinguishable from a causal 4-week persistence forecast (H1b), which the study's own mandatory baselines (Section 4.3) show to be a far harder bar than static expert scoring: persistence alone removes 97% of the error relative to climatology. The pooled margin over the matched model is dominated by the first block, where training is thinnest, so it is read as suggestive of a structural advantage of the vulnerability/environmental/threat decomposition and is not evidence for one (Section 4.5). Against the flat ANFIS variants, HANFIS lowers parameters and peak training memory but not training time or single-row latency (Section 4.15).

Post hoc analyses qualify this further. The model's skill rests on exploitability and KEV (78.9% of the exact Shapley attribution; without them it has no skill over CVSS), and a four-parameter formula of those two inputs has a lower error than HANFIS (Sections 4.7 and 4.8). On this target HANFIS therefore provides a compact rule base with a documented response surface, while its four-week accuracy stays below that of a simple formula. Its intermediate variables do not keep a stable linguistic meaning across trained models (Section 4.10). The pre-registered forward evaluation (Section 4.16) points the same way: the accuracy of HANFIS on this task is bounded by a simple formula, and what the model adds is a printable structure. At eight and

twelve weeks the gap narrows but does not close on rows unaffected by the EPSS model change, and the other inputs do not contribute (Sections 4.11 and 4.13). Whether environmental context improves forecasts remains open. Two further results are documented: the sealed, hash-verified real-world data pipeline (120 assets and 6,357 labelled asset-weeks, Section 3.4) and an ablation on two synthetic scenarios indicating that the monotonicity constraint has a membership-family-dependent accuracy cost, met in practice only for the dominant drivers (Sections 4.5 and 4.7).

Three points follow for practice and for later work. For ranking near-term exploitability exposure from EPSS and KEV signals, the max-form formula, with persistence as the bar that any alternative must beat, is the choice the evidence supports (Section 5). A hierarchical neuro-fuzzy model is worth building only where an auditable rule structure is required, or where an outcome that depends on the environment, such as incident or impact data, is available to test the environmental panel; the present target cannot show that benefit even if it exists. The result concerns one architecture, one label and one six-week forward window, and it does not extend to other EPSS model versions, other image sets or other neuro-fuzzy designs.

H1b against persistence remains unconfirmed, and the forward weeks did not support it either (P7a). The bottleneck-width sweep (Section 4.4) found that widening the scalar inter-tier bottleneck from $k$=1 to $k$=2 does not close the gap to persistence; the wider model is significantly worse than persistence. Re-scanning every image with a single frozen vulnerability database, so that no image's CVE surface differs merely because it was scanned on a different day, was done once for the forward evaluation (Section 4.16); the earlier 57-week window still rests on scans from different days. The policy-translation layer (not a contribution of this paper) and edge deployment (originally hypothesis H5, now future work because the present testbed runs HANFIS cluster-side rather than on its edge node) remain designed but unevaluated. Both are left for a subsequent study.

# List of abbreviations

*AI* Artificial intelligence

*ANFIS* Adaptive neuro-fuzzy inference system

*ANN* Artificial neural network

*CI* Confidence interval

*CISA* Cybersecurity and Infrastructure Security Agency

*CPU* Central processing unit

*CVE* Common Vulnerabilities and Exposures

*CVSS* Common Vulnerability Scoring System

*DOI* Digital Object Identifier

*EPSS* Exploit Prediction Scoring System

*FIS* Fuzzy inference system

*HANFIS* Hierarchical adaptive neuro-fuzzy inference system

*HTTP* Hypertext Transfer Protocol

*KEV* Known Exploited Vulnerabilities

*LPPM* Institute for Research and Community Service

*MFA* Multi-factor authentication

*MSE* Mean squared error

*OSF* Open Science Framework

*RMSE* Root mean squared error

*SHA* Secure Hash Algorithm

*SS* Skill score

*WSL* Windows Subsystem for Linux

# Additional files

- **Additional file 1.** Format: PDF. Title: Supplementary tables, figures and notes. Description: Tables S1 to S17 (acceptance gates of the testbed, the membership-family ablation, the EPSS-change sensitivity run, explanation-fidelity checks, ranking utility, input-change strata, calibration, forward-evaluation details, the trained rule base of one model, the observability-overhead measurements, the horizon sweep, the error anatomy by EPSS model change, and the map from experiment and amendment codes to sections); Figures S1 to S5 (methodology overview, baseline and skill-score plots, the response surface of one trained model, and the bottleneck-width curve); Supplementary notes S1 to S12 (full text of the sections that the main text condenses: study design of the overhead experiment, testbed and observability-overhead protocol with its validity safeguards, ablation details, explanation fidelity, ranking utility, error anatomy, calibration and stacking, data caveats, the horizon sweep and the accuracy-complexity sweep).

# Declarations


- **Funding.** This work is supported by the Penelitian Kepakaran research grant, Institute for Research and Community Service (LPPM), Universitas Andalas, Indonesia. The funder had no role in the design of the study, in the collection, analysis or interpretation of data, or in writing the manuscript.


- **Competing interests.** The authors declare no competing interests.
- **Ethics approval and consent to participate.** Not applicable: this study involves no human participants, human data, or animal subjects. All measurements were collected from an isolated Kubernetes research testbed operated by the authors.
- **Consent for publication.** Not applicable.
- **Availability of data and materials.** The Zenodo archive (version 2.0, DOI `10.5281/zenodo.24133609`; version 1.0 is `10.5281/zenodo.23357118`) holds the

frozen protocols, the SHA-256 manifests of the sealed weekly EPSS snapshots and of the KEV catalogue, the 25 saved models of the confirmatory run, the five final models and the outputs of the forward evaluation, the results of the computational-cost measurement and of the two post hoc analyses of Sections 4.15 to 4.10, Additional file 1, the derived asset-week tables from which the analyses were run, and the Trivy scan outputs of a subset of the images. The weekly EPSS and KEV snapshot files are not redistributed; they can be obtained from their publishers and checked against the manifests. The full set of scan outputs and the raw telemetry outputs of the ten paired observability-overhead runs (Runs 7–16) are not part of the archive. The forward-evaluation protocol is registered at the Open Science Framework Hersyah et al. (2026).

- **Code availability.** The HANFIS implementation, data pipeline and experiment scripts are archived at Zenodo (DOI `10.5281/zenodo.24133609`) and developed in the public repository `github.com/udahafeez7/HANFIS-RESEARCH`.
- **Authors' contributions.** M.H.H.: conceptualisation, methodology, software, experimentation, writing – original draft. D.D.: supervision, contribution to the neural network component, methodology review, writing – review and editing. B.R.: supervision, contribution to the design of the experimental platform (cluster and telemetry network), methodology review, writing – review and editing. All authors read and approved the final manuscript.
- **Use of AI tools.** During the preparation of this work the authors used an AI assistant (Claude, Anthropic; Claude Sonnet 5.5, Claude Opus 5.5 and Claude Fable 5.1 models, September to November 2026) to help write and test code, to draft the two unregistered protocols, to run scripts at the authors' direction, to draft and revise manuscript text, and to check references. The authors decided every protocol and claim, verified all code, results and references, reviewed and edited all text, and take full responsibility for the content of the publication. The assistant is not an author.

• **Acknowledgements.** The authors thank the Institute for Research and Community Service (LPPM), Universitas Andalas, for supporting this work.

# References

Allodi L, Massacci F (2014) Comparing vulnerability severity and exploits using case-control studies. ACM Transactions on Information and System Security 17(1):1–20. https://doi.org/10.1145/2630069

Aqua Security (2026) Trivy. https://github.com/aquasecurity/trivy, version 0.74.0; vulnerability database of 2 October 2026

Brown M, Bossley KM, Mills DJ, et al (1995) High dimensional neurofuzzy systems: overcoming the curse of dimensionality. In: Proceedings of 1995 IEEE International Conference on Fuzzy Systems, vol 4. IEEE, pp 2139–2146, https://doi.org/10.1109/FUZZY.1995.409976

Chandramouli R (2019) Security strategies for microservices-based application systems. Tech. Rep. NIST Special Publication 800-204, National Institute of Standards and Technology, https://doi.org/10.6028/NIST.SP.800-204

Chandramouli R, Butcher Z (2023) A zero trust architecture model for access control in cloud-native applications in multi-location environments. Tech. Rep. NIST Special Publication 800-207A, National Institute of Standards and Technology, https://doi.org/10.6028/NIST.SP.800-207A

Chiu SL (1994) Fuzzy model identification based on cluster estimation. Journal of Intelligent & Fuzzy Systems 2(3):267–278. https://doi.org/10.3233/IFS-1994-2306

Cybersecurity and Infrastructure Security Agency (2026) Known exploited vulnerabilities catalog. https://www.cisa.gov/known-exploited-vulnerabilities-catalog, weekly

snapshots, 25 August 2025 to 21 September 2026

Efron B (1979) Bootstrap methods: Another look at the jackknife. The Annals of Statistics 7(1):1–26. https://doi.org/10.1214/aos/1176344552

FIRST.org, Inc. (2023) Common vulnerability scoring system version 4.0: Specification document. https://www.first.org/cvss/v4.0/specification-document, accessed 6 October 2026

Hafiz Hersyah M, Hossain MD, Taenaka Y, et al (2025) Fuzzyfortify: a multi-attribute risk assessment for multi-factor authentication and cloud container orchestration. Frontiers in Computer Science 7:1557918. https://doi.org/10.3389/fcomp.2025.1557918

Hersyah MH, Derisma D, Rahmadya B (2026) HANFIS prospective evaluation (E7). Open Science Framework registration of the pre-registered forward-evaluation protocol, https://doi.org/10.17605/OSF.IO/AHCVS, registered 13 October 2026; accessed 11 November 2026

Holm S (1979) A simple sequentially rejective multiple test procedure. Scandinavian Journal of Statistics 6(2):65–70

Jabeen S, Baig M, Awais MM (2023) ANFIS learning using expectation maximization based Gaussian mixture model and multilayer perceptron learning. Applied Soft Computing 149:110958. https://doi.org/10.1016/j.asoc.2023.110958

Jacobs J, Romanosky S, Adjerid I, et al (2020) Improving vulnerability remediation through better exploit prediction. Journal of Cybersecurity 6(1):tyaa015. https://doi.org/10.1093/cybsec/tyaa015

Jacobs J, Romanosky S, Edwards B, et al (2021) Exploit prediction scoring system (EPSS). Digital Threats: Research and Practice 2(3):1–17. https://doi.org/10.1145/3436242

Jacobs J, Romanosky S, Suciu O, et al (2023) Enhancing vulnerability prioritization: Data-driven exploit predictions with community-driven insights. In: 2023 IEEE European Symposium on Security and Privacy Workshops (EuroS&PW). IEEE, pp 194–206, https://doi.org/10.1109/EuroSPW59978.2023.00027

Jang JSR (1993) ANFIS: Adaptive-network-based fuzzy inference system. IEEE Transactions on Systems, Man, and Cybernetics 23(3):665–685. https://doi.org/10.1109/21.256541

Joint Task Force Transformation Initiative (2012) Guide for conducting risk assessments. Tech. Rep. NIST Special Publication 800-30 Rev. 1, National Institute of Standards and Technology, https://doi.org/10.6028/NIST.SP.800-30r1

Juston MFR, Dekhterman SR, Norris WR, et al (2024) Hierarchical rule-base reduction-based ANFIS with online optimization through DDPG. IEEE Transactions on Fuzzy Systems 32(11):6350–6362. https://doi.org/10.1109/TFUZZ.2024.3449147

Kim Y, Park C, Hong D (2025) A robust framework for comprehensive container image vulnerability assessment. IEEE Access 13:35837–35847. https://doi.org/10.1109/ACCESS.2025.3545124

Koscinski V, Nelson M, Okutan A, et al (2025) Conflicting scores, confusing signals: An empirical study of vulnerability scoring systems. In: Proceedings of the 2025 ACM SIGSAC Conference on Computer and Communications Security. ACM, pp 1904–1918, https://doi.org/10.1145/3719027.3765210

Lee ML, Chung HY, Yu FM (2003) Modeling of hierarchical fuzzy systems. Fuzzy Sets and Systems 138(2):343–361. https://doi.org/10.1016/S0165-0114(02)00517-1

Mills A, White J, Legg P (2023) Longitudinal risk-based security assessment of docker software container images. Computers & Security 135:103478. https://doi.org/10.1016/j.cose.2023.103478

Minna F, Blaise A, Rebecchi F, et al (2021) Understanding the security implications of Kubernetes networking. IEEE Security & Privacy 19(5):46–56. https://doi.org/10.1109/MSEC.2021.3094726

Ojha V, Abraham A, Snášel V (2019) Heuristic design of fuzzy inference systems: A review of three decades of research. Engineering Applications of Artificial Intelligence 85:845–864. https://doi.org/10.1016/j.engappai.2019.08.010

Parthiban S, Krishna S (2026) Hierarchical ANFIS-SMC framework for eco-driving-based energy optimization of electric vehicles. IEEE Access 14:71845–71855. https://doi.org/10.1109/ACCESS.2026.3692296

Rahman A, Shamim SI, Bose DB, et al (2023) Security misconfigurations in open source Kubernetes manifests: An empirical study. ACM Transactions on Software Engineering and Methodology 32(4):1–36. https://doi.org/10.1145/3579639

Raju GVS, Zhou J, Kisner RA (1991) Hierarchical fuzzy control. International Journal of Control 54(5):1201–1216. https://doi.org/10.1080/00207179108934205

Rose S, Borchert O, Mitchell S, et al (2020) Zero trust architecture. Tech. Rep. NIST Special Publication 800-207, National Institute of Standards and Technology, https://doi.org/10.6028/NIST.SP.800-207

Shapley LS (1953) A value for $n$-person games. In: Contributions to the Theory of Games (AM-28), Volume II. Princeton University Press, p 307–318, https://doi.org/10.1515/9781400881970-018

Shimizu N, Hashimoto M (2026) Vulnerability management chaining: An integrated framework for efficient cybersecurity risk prioritization. IEEE Access 14:31407–31424. https://doi.org/10.1109/ACCESS.2026.3665768

Shu R, Gu X, Enck W (2017) A study of security vulnerabilities on Docker Hub. In: Proceedings of the Seventh ACM on Conference on Data and Application Security and Privacy. ACM, pp 269–280, https://doi.org/10.1145/3029806.3029832

Soozanchi-K. Z, Akbarzadeh-T. MR, Yaghoobi M, et al (2010) Speaker verification system using a hierarchical adaptive network-based fuzzy inference systems (HANFIS). In: Artificial Intelligence in Theory and Practice III. IFIP Advances in Information and Communication Technology, Springer Berlin Heidelberg, p 233–237, https://doi.org/10.1007/978-3-642-15286-3_23

Souppaya M, Morello J, Scarfone K (2017) Application container security guide. Tech. Rep. NIST Special Publication 800-190, National Institute of Standards and Technology, https://doi.org/10.6028/NIST.SP.800-190

Spring J, Hatleback E, Householder A, et al (2021) Time to change the CVSS? IEEE Security & Privacy 19(2):74–78. https://doi.org/10.1109/MSEC.2020.3044475

The Kubernetes Authors (2026) Pod lifecycle. https://kubernetes.io/docs/concepts/workloads/pods/pod-lifecycle/, accessed 6 October 2026

The Prometheus Authors (2026) Prometheus: Overview. https://prometheus.io/docs/introduction/overview/, accessed 14 October 2026

Torra V (2002) A review of the construction of hierarchical fuzzy systems. International Journal of Intelligent Systems 17(5):531–543. https://doi.org/10.1002/int.10036

Wang LX (1998) Universal approximation by hierarchical fuzzy systems. Fuzzy Sets and Systems 93(2):223–230. https://doi.org/10.1016/S0165-0114(96)00197-2

Wu HM, Zaman MQ (2025) Enhanced hierarchical fuzzy formation control with fuzzy collision avoidance behavior for multiple Mecanum wheeled mobile robots. Robotics and Autonomous Systems 194:105124. https://doi.org/10.1016/j.robot.2025.105124

Zeng XJ, Keane JA (2005) Approximation capabilities of hierarchical fuzzy systems. IEEE Transactions on Fuzzy Systems 13(5):659–672. https://doi.org/10.1109/TFUZZ.2005.856559

Zerouali A, Mens T, Robles G, et al (2019) On the relation between outdated Docker containers, severity vulnerabilities, and bugs. In: 2019 IEEE 26th International Conference on Software Analysis, Evolution and Reengineering (SANER). IEEE, pp 491–501, https://doi.org/10.1109/SANER.2019.8668013

Zhang Y, Wang G, Zhou T, et al (2024) Takagi-sugeno-kang fuzzy system fusion: A survey at hierarchical, wide and stacked levels. Information Fusion 101:101977. https://doi.org/10.1016/j.inffus.2023.101977